

Laporan Audit Keamanan

Personal Life OS - Aplikasi APK & Layanan Akun/Sinkron

Tanggal audit: 26 September 2026 (diambil 03:54 WIB)

Penyusun: Aaron Salahuddin - pakar keamanan siber (red team & blue team)

Lingkup: kode aplikasi Android (Dart/Flutter) dan kode layanan server akun & sinkron (Python/FastAPI) beserta konfigurasi container dan pintu depannya.

1. Ringkasan eksekutif

Audit menemukan 18 hal yang perlu diperhatikan: 1 tingkat tinggi, 6 tingkat sedang, 10 tingkat rendah, 1 catatan. Sebanyak 14 sudah diperbaiki dan diverifikasi pada hari yang sama; sisanya adalah pekerjaan/keputusan lanjutan (bukan kesalahan yang sedang terbuka lebar).

Temuan paling berat ada di sisi APLIKASI, bukan server.

Mesin sinkron menerima nama kolom dari luar lalu memakainya menyusun perintah SQL. Jalur ini bisa dicapai lewat berkas sinkron kiriman orang lain, jadi bukan sekadar kemungkinan di atas kertas. Sudah ditutup dengan daftar-putih kolom dari skema, dan impor berkas tetap bersifat semua-atau-tidak-sama-sekali supaya tidak ada data yang masuk setengah.

Sisi server dasarnya sudah kuat: isolasi akun, sandi di-hash scrypt, token disimpan sebagai hash, TLS 1.3.

Yang diperbaiki hari ini terutama soal ketahanan: kebocoran lewat waktu di pintu masuk, waktu kiriman dari klien yang dipakai mentah, batas ukuran dan kuota, pembatas laju di pintu depan, hak akses berkas, proses non-root, catatan peristiwa keamanan, serta dokumentasi API yang sebelumnya terbuka.

2. Metode & ruang lingkup

- Telaah kode statis: seluruh kode aplikasi (Dart) pada pohon rilis dan seluruh kode server (Python, Dockerfile, compose, konfigurasi nginx).
- Pencarian rahasia (secret hunting) pada riwayat repo dan berkas konfigurasi.
- Uji langsung ke layanan hidup: header, TLS, metode HTTP, percobaan lintas jalur, batas ukuran, galat, pembatas percobaan, isolasi antar akun.
- Ujilah-pakai (proof by test): uji otomatis baru ditulis untuk setiap perbaikan, dijalankan di lingkungan uji terpisah.
- Verifikasi sesudah perbaikan: setiap temuan yang diperbaiki diperiksa ulang pada layanan hidup, bukan hanya di kode.

3. Daftar temuan

ID	Tingkat	Temuan	Status
A-01	HIGH	Suntikan SQL lewat nama kolom pada penerapan data sinkron	DIPERBAIKI + diuji
A-02	LOW	Pembangkit UID memakai acak tidak aman di 4 berkas	DIPERBAIKI
A-03	INFO	Penolong uidBaru() tergandang di banyak berkas	Terbuka (rendah)
S-01	MEDIUM	Kebocoran lewat waktu pada pintu masuk (enumerasi email)	DIPERBAIKI + diuji
S-02	MEDIUM	Waktu kiriman (waktu_klien) dari klien dipakai mentah	DIPERBAIKI + diuji
S-03	MEDIUM	Tanpa batas ukuran catatan & tanpa kuota per akun	DIPERBAIKI + diuji
S-04	MEDIUM	Peta pembatas percobaan bisa tumbuh tanpa batas	DIPERBAIKI
S-05	MEDIUM	Parameter hash sandi tidak tersimpan & perbandingan tidak waktu-tetap	DIPERBAIKI
S-06	LOW	Dokumentasi API terbuka untuk umum	DIPERBAIKI (kini 404)
S-07	LOW	Galat validasi memantulkan isi kiriman	DIPERBAIKI + diuji (36 byte, tanpa isi)

S-08	LOW	Berkas basis data dapat dibaca siapa saja & proses berjalan sebagai root	DIPERBAIKI + diverifikasi
S-09	LOW	Kesalahan nama variabel lingkungan (pengaturan tidak berlaku)	DIPERBAIKI
S-10	LOW	Tanpa pemeriksaan kesehatan container & tanpa rotasi log	DIPERBAIKI (status healthy)
S-11	LOW	Tanpa pembatas laju di lapisan nginx	DIPERBAIKI + diuji (49 permintaan/detik: 328 ditahan)
S-12	LOW	Tidak ada catatan peristiwa keamanan	DIPERBAIKI + diverifikasi
S-13	MEDIUM	Data sinkron disimpan tanpa enkripsi di server	TERBUKA - butuh keputusan Papi
S-14	LOW	Belum ada verifikasi email & sedikit pemeriksaan kekuatan sandi	Terbuka (rendah)
S-15	LOW	Umur token 90 hari tanpa penyegaran	Terbuka (rendah)

4. Rincian temuan & perbaikan

A-01 - Suntikan SQL lewat nama kolom pada penerapan data sinkron [HIGH]

Temuan: Mesin sinkron menyusun perintah SQL memakai nama kolom yang datang dari LUAR (payload server atau berkas sinkron kiriman orang lain). Nilai selalu lewat parameter, tetapi nama kolomnya belum disaring sehingga nama kolom palsu ikut menjadi perintah SQL. Jalur ini bisa dicapai lewat berkas sinkron kiriman orang lain (fitur berbagi antar perangkat/keluarga) atau server yang dikuasai penyerang.

Bukti: lib/core/sinkron/sinkron_semua.dart: UPDATE ... SET \$k = ? dan INSERT ... (kolom.join(', ')) memakai kunci dari payload. Diuji: payload memuat kolom 'isi' VALUES (SUNTIKAN) --'.

Perbaikan: Daftar-putih kolom dari skema (kolomSahTabel). Nama kolom di luar skema DIBUANG; pada jalur berkas impor dibatalkan seluruhnya (atomic) agar tidak ada data masuk setengah.

Status: DIPERBAIKI + diuji

A-02 - Pembangkit UID memakai acak tidak aman di 4 berkas [LOW]

Temuan: Empat repositori memakai Random() biasa untuk membuat uid baris, bukan Random.secure().

Bukti: tagihan_repository.dart:40, jurnal_perjalanan_repository.dart:23, perjalanan_repository.dart:20, tanggung_jawab_repository.dart:24.

Perbaikan: Diganti Random.secure() (uidBaru pada tagihan tetap menerima acak tersuntik untuk uji).

Status: DIPERBAIKI

A-03 - Penolong uidBaru() tergandang di banyak berkas [INFO]

Temuan: Puluhan berkas menyalin fungsi uidBaru() sendiri-sendiri; ini yang membuat varian acak lemah (A-02) mudah muncul kembali.

Bukti: Puluhan berkas di lib/data/repository/*.dart memiliki salinan uidBaru().

Perbaikan: Rekomendasi: satu penolong bersama (belum dikerjakan, perubahan menyentuh banyak berkas).

Status: Terbuka (rendah)

S-01 - Kebocoran lewat waktu pada pintu masuk (enumerasi email) [MEDIUM]

Temuan: Saat email tidak terdaftar, server langsung menolak tanpa menjalankan scrypt; saat email ada, scrypt berjalan. Perbedaan waktu jawaban membocorkan apakah sebuah email punya akun.

Bukti: Biaya hash_sandi(scrypt n=2^14) terukur 36,2 ms; email tidak ada dijawab ~0,5 ms.

Perbaikan: samakan_waktu_sandi(): scrypt tetap dijalankan walau akun tidak ada. Pembandingan sandi juga diganti secrets.compare_digest (waktu tetap).

Status: DIPERBAIKI + diuji

S-02 - Waktu kiriman (waktu_klien) dari klien dipakai mentah [MEDIUM]

Temuan: Penentuan versi menang/kalah membandingkan waktu kiriman sebagai TEKS tanpa validasi. Perangkat dengan jam ngawur (atau klien jahat) selalu bisa menang atas versi lain, dan format waktu berbeda membuat perbandingan salah.

Bukti: main.py: perbandingan lama['waktu_klien'] > p.waktu_klien (teks); waktu_klien hanya dibatasi panjang 10-40 karakter.

Perbaikan: waktu_klien_baku(): dibaca sebagai waktu, dibakukan ke UTC milidetik, bentuk tak sah ditolak (422), waktu > 1 hari ke depan dibatasi.

Status: DIPERBAIKI + diuji

S-03 - Tanpa batas ukuran catatan & tanpa kuota per akun [MEDIUM]

Temuan: Satu akun dapat menyimpan catatan sebesar apa pun, tanpa batas jumlah. Kiriman besar berulang dapat menghabiskan memori dan ruang disk server (gangguan layanan).

Bukti: main.py: isi = dict bebas; tidak ada batas byte maupun hitungan baris per akun.

Perbaikan: Batas 64 KB per catatan (HTTP 413) dan kuota 200.000 catatan per akun (HTTP 429) + batas 500 perubahan per kiriman.

Status: DIPERBAIKI + diuji

S-04 - Peta pembatas percobaan bisa tumbuh tanpa batas [MEDIUM]

Temuan: Riwayat percobaan masuk yang gagal disimpan di memori per alamat, dan hanya dibersihkan saat alamat itu dipakai lagi. Alamat yang tidak kembali lagi tidak pernah dibuang.

Bukti: main.py: _percobaan[ip] = ... tanpa pembersihan menyeluruh/batas jumlah kunci.

Perbaikan: _bersihkan_peta_percobaan(): pembersihan menyeluruh tiap 30 detik + batas 20.000 alamat (yang paling lama dibuang lebih dulu).

Status: DIPERBAIKI

S-05 - Parameter hash sandi tidak tersimpan & perbandingan tidak waktu-tetap [MEDIUM]

Temuan: Nilai hash lama tidak memuat parameter scrypt, sehingga parameter tidak bisa dinaikkan kelak tanpa memutus semua sandi. Perbandingan memakai != biasa (bukan waktu tetap).

Bukti: main.py: hash_sandi menghasilkan hex polos; perbandingan != saat masuk/ganti sandi.

Perbaikan: Format baru scrypt\$N\$R\$P\$hash + sandi_cocok() dengan secrets.compare_digest; hash lama otomatis dinaikkan saat pengguna masuk.

Status: DIPERBAIKI

S-06 - Dokumentasi API terbuka untuk umum [LOW]

Temuan: /docs, /redoc, dan /openapi.json dapat dibuka siapa saja sehingga memetakan seluruh pintu API (memudahkan penyusunan serangan).

Bukti: Permintaan ke <https://coder.sam.university/lifeos-api/docs> menjawab 200.

Perbaikan: Tertutup secara bawaan; hanya terbuka bila LIFEOS_DOKUMEN=1 (untuk pengembangan).

Status: DIPERBAIKI (kini 404)

S-07 - Galat validasi memantulkan isi kiriman [LOW]

Temuan: Jawaban galat 422 memuat kembali isi kiriman (termasuk data pribadi) sehingga ukuran jawaban bisa jauh lebih besar daripada permintaannya.

Bukti: Kiriman nama 4 MB dijawab 422 dengan isi 'input' ikut dikembalikan.

Perbaikan: Penangan galat khusus: jawaban hanya memuat letak & jenis kesalahan.

Status: DIPERBAIKI + diuji (36 byte, tanpa isi)

S-08 - Berkas basis data dapat dibaca siapa saja & proses berjalan sebagai root [LOW]

Temuan: Berkas basis data (berisi data keuangan & kesehatan) bermode 644, dan proses aplikasi berjalan sebagai root di dalam container.

Bukti: `ls -la: -rw-r--r-- lifeos-sync.db; docker exec id -> uid=0(root).`

Perbaikan: Berkas diatur 600 (termasuk WAL/SHM) dan container berjalan sebagai pengguna biasa uid 10001 (USER lifeos + user: 10001:10001).

Status: DIPERBAIKI + diverifikasi

S-09 - Kesalahan nama variabel lingkungan (pengaturan tidak berlaku) [LOW]

Temuan: Container berjalan dengan variabel LIFEOS_UMUR_TOKEN sementara kode membaca LIFEOS_UMUR_TOKEN_HARI; container juga belum dibuat ulang sesudah berkas compose diubah sehingga pengaturan nyata berbeda dari yang tertulis (config drift).

Bukti: `docker inspect: LIFEOS_UMUR_TOKEN ada; grep kode: LIFEOS_UMUR_TOKEN_HARI.`

Perbaikan: Container dibuat ulang dari berkas compose yang benar (lihat verifikasi /sehat versi 1.1.0).

Status: DIPERBAIKI

S-10 - Tanpa pemeriksaan kesehatan container & tanpa rotasi log [LOW]

Temuan: Tidak ada healthcheck sehingga container yang macet tetap tampak berjalan; log container tumbuh tanpa batas.

Bukti: `docker inspect: Healthcheck TIDAK ADA.`

Perbaikan: HEALTHCHECK di Dockerfile + logging max-size 10m, max-file 3.

Status: DIPERBAIKI (status healthy)

S-11 - Tanpa pembatas laju di lapisan nginx [LOW]

Temuan: Pembatas hanya ada di aplikasi (dan hanya untuk daftar/masuk). Belum ada jaring pengaman di pintu depan untuk menahan banjir permintaan.

Bukti: `grep limit_req di /etc/nginx: tidak ada.`

Perbaikan: Zona limit_req 20 permintaan/detik dengan lonjakan 40, berlaku di lokasi /lifeos-api/.

Status: DIPERBAIKI + diuji (49 permintaan/detik: 328 ditahan)

S-12 - Tidak ada catatan peristiwa keamanan [LOW]

Temuan: Tidak ada rekaman masuk gagal/berhasil, penggantian sandi, penghapusan akun, atau tercapainya batas percobaan sehingga serangan tidak bisa ditelusuri.

Bukti: `main.py: tidak ada penulisan log peristiwa.`

Perbaikan: `keamanan.log` (JSON per baris, rotasi 5 MB): daftar baru, masuk gagal/berhasil, sandi diganti, akun dihapus, batas percobaan, kuota penuh. Tidak pernah memuat sandi/token.

Status: DIPERBAIKI + diverifikasi

S-13 - Data sinkron disimpan tanpa enkripsi di server [MEDIUM]

Temuan: Isi sinkron (keuangan & kesehatan) disimpan sebagai teks di basis data server. Bila server dikuasai pihak lain, seluruh isi keluarga dapat dibaca. Ini keputusan rancangan, bukan kesalahan kode.

Bukti: Berkas lifeos-sync.db berupa SQLite polos; kolom isi berupa JSON teks.

Perbaikan: Rekomendasi (belum dikerjakan): enkripsi di sisi aplikasi dengan kunci turunan sandi akun sehingga server hanya menyimpan data terenkripsi; atau enkripsi disk server.

Status: TERBUKA - butuh keputusan Papi

S-14 - Belum ada verifikasi email & sedikit pemeriksaan kekuatan sandi [LOW]

Temuan: Siapa pun dapat mendaftar dengan email yang bukan miliknya, dan sandi hanya dibatasi minimal 8 karakter.

Bukti: main.py: sandi Field(min_length=8); tidak ada verifikasi email.

Perbaikan: Catatan: ambang 8 karakter sejalan panduan NIST, tetapi untuk layanan publik sebaiknya ditambah pemeriksaan daftar sandi umum dan verifikasi email.

Status: Terbuka (rendah)

S-15 - Umur token 90 hari tanpa penyegaran [LOW]

Temuan: Token berlaku 90 hari tanpa rotasi; ponsel yang hilang tetap bisa mengakses sampai token kedaluwarsa (hanya bisa diputus lewat ganti sandi).

Bukti: main.py: UMUR_TOKEN_HARI bawaan 90; belum ada daftar sesi per perangkat.

Perbaikan: Catatan: pertimbangkan penyegaran token berkala + daftar perangkat aktif yang bisa dicabut satu per satu.

Status: Terbuka (rendah)

5. Yang sudah baik (dipertahankan)

- Isolasi akun terbukti: 18/18 pemeriksaan lulus, termasuk akun B tidak dapat melihat data akun A; setiap query disaring akun_id.
- Token sesi 32 byte acak, yang tersimpan hanya hash SHA-256; token mati setelah keluar.
- Sandi di-hash script (tanpa sandi mentah di basis data) dan perbandingan waktu-tetap.
- TLS 1.3 aktif, TLS 1.0/1.1 ditolak, sertifikat sah (Let's Encrypt).
- Header keamanan lengkap di jalur API (HSTS, nosniff, X-Frame-Options, Referrer-Policy, Permissions-Policy).
- Port layanan hanya terikat 127.0.0.1 (tidak terbuka langsung ke internet).
- Percobaan lintas jalur (path traversal) ditolak 400/404; metode HTTP tak wajar dijawab 405.
- Pembatas percobaan masuk tidak bisa dilewati dengan memalsukan X-Forwarded-For (diuji).
- Aplikasi: verifikasi sertifikat tidak pernah dimatikan, tanpa alamat http:// untuk data, usesCleartextTraffic=false, CA pengguna tidak dipercaya.
- Aplikasi: allowBackup=false + aturan pengambilan data mengecualikan semuanya; FileProvider hanya membagikan salinan di cache/bagikan.
- Aplikasi: PIN disimpan sebagai turunan PBKDF2-HMAC-SHA256 600.000 putaran (selaras OWASP).
- Aplikasi: izin minimal (tanpa akses SMS/kontak), pemindaian rahasia repo bersih.

6. Langkah lanjutan yang disarankan

- 1. Enkripsi data sinkron di sisi aplikasi (S-13) - pekerjaan berikutnya yang paling berdampak. Kunci diturunkan dari sandi akun sehingga server hanya menyimpan teks terenkripsi.
- 2. Satu penolong uid bersama untuk seluruh repositori (A-03) supaya varian acak lemah tidak muncul lagi.
- 3. Verifikasi email + pemeriksaan daftar sandi umum saat layanan dibuka untuk publik (S-14).

- 4. Daftar perangkat aktif yang bisa dicabut satu per satu + penyegaran token (S-15).
- 5. Naikkan skala penyimpanan ke PostgreSQL + replika sebelum jumlah pengguna besar; sertakan kuota, pemantauan, dan cadangan otomatis.

7. Hasil pengujian (bukti)

Pengujian	Hasil
Uji API akun & sinkron (18 pemeriksaan)	18 dari 18 lulus
Uji isolasi antar akun (akun B tidak melihat data A)	Lulus
Uji aturan konflik (versi lebih baru menang, versi kalah disimpan)	Lulus
Uji nyata kode APLIKASI ke server, jalur dalam (16 pemeriksaan)	16 dari 16 lulus
Uji nyata kode APLIKASI ke server, jalur HTTPS publik	16 dari 16 lulus
Uji suntikan nama kolom pada penerapan sinkron (4 uji di aplikasi)	4 dari 4 lulus
Daftar putih kolom terisi untuk seluruh 75 jalur sinkron	Lulus
Suite uji penuh aplikasi	1.492 lulus, 1 dilewati, 0 gagal
Analisa statis aplikasi (23 aturan)	Bersih, tanpa temuan
Uji impor berkas sinkron rusak wajib dibatalkan seluruhnya	Lulus
Batas ukuran catatan 64 KB	HTTP 413 (ditolak)
Waktu kiriman tidak sah / tahun 2099	HTTP 422 / dibatasi ke 2026-09-27
Jumlah perubahan 600 dalam satu kiriman	HTTP 422 (ditolak)
Galat validasi tidak memantulkan isi kiriman	36 byte, tanpa isi
Dokumentasi API /docs, /redoc, /openapi.json	404 (tertutup)
Pembatas laju nginx (49 permintaan/detik)	328 permintaan ditahan (429)
Hak akses berkas basis data	600 (-rw-----)
Proses container	uid 10001 (bukan root)
Pemeriksaan kesehatan container	healthy
Versi layanan sesudah perbaikan	1.1.0

8. Batasan audit

Yang TIDAK diuji pada audit ini - disebutkan supaya laporan ini tidak dibaca berlebihan:

- Tidak diuji dari perangkat Android asli (perilaku Keystore, migrasi data di HP, notifikasi).
- Tidak ada uji beban skala besar; server masih SQLite satu pekerja, batas nyata belum diukur.
- Tidak diuji layanan lain di server Austria - lingkup audit hanya layanan akun & sinkron Personal Life OS serta kode aplikasinya.
- Analisis CVE dependensi terbatas pada pemeriksaan versi terpasang (fastapi 0.115.6, uvicorn 0.34.0, pydantic 2.10.4, starlette 0.41.3) dengan pencarian sumber terbuka; tidak memakai basis data paket (pip-audit) karena tidak dipasang.
- Tidak diuji pemulihan bencana (server hilang), enkripsi disk, dan kebijakan cadangan server.
- Tidak ada pengujian terhadap akun/data nyata: semua uji memakai akun buangan yang langsung dihapus (siswa akun terverifikasi 0).
- Kredensial tidak pernah ditampilkan dalam laporan ini; nilai sensitif disamarkan.

9. Pernyataan otorisasi

Seluruh pengujian dilakukan pada aset milik Papi sendiri (aplikasi Personal Life OS dan layanan akun di server Austria). Tidak ada pengujian terhadap aset pihak ketiga. Semua uji memakai akun buangan yang dihapus setelah pengujian; data pengguna nyata tidak disentuh. Nilai kredensial tidak ditampilkan dalam laporan ini.

10. Disclaimer

DISCLAIMER: Audit/analisa ini dilakukan HANYA pada aset milik/berizin pemilik dengan tujuan keamanan dan edukasi. Temuan dilaporkan untuk diperbaiki, BUKAN untuk dieksploitasi pihak ketiga. Informasi sensitif (kredensial, path eksploitasi detail) tidak dibagikan ke publik. Setiap penggunaan informasi ini di luar konteks yang sah sepenuhnya menjadi tanggung jawab pengguna. Penyusun tidak bertanggung jawab atas kerugian dalam bentuk apa pun yang timbul dari penyalahgunaan informasi ini.

Disusun oleh Dato' Dr. H. Sami'an, M.B.A